Broker and Customer Access Management Modernization

Technical Requirements - USE CASES

October 02, 2026

1. Use Cases

UC #	Use Case	
UC-01	Self-Service User Registration & Progressive Profiling	**B2C**
UC-02	Passkeys/FIDO2 Password-less Authentication with OTP and authenticator-app fallback	**B2C**
UC-03	Account Recovery & Self-Service Credential Reset during locked-out or credential-loss scenarios	**B2C**
UC-04	Trusted device registration for receiving OTP push notifications.	**B2C**
UC-05	Risk-Based Adaptive Authentication & Fraud Signal Integration	**B2C/B2B**
UC-06 **UC-07**	Simplified Insurance Use Cases (Information query, Document Request, Simple Transaction, Sensitive Transaction, App-to-Voice transfer (client authenticated in an app and transferred to contact center bot/agent without reauthentication)	**B2C**
UC-08	Single Sign-on & Cross Application Federation	**B2C/B2B**
UC-09	API Security – OAuth complaint third-party access to IFC external APIs	**B2C/B2B**
UC-10	Customizable Login Facility	**B2C/B2B**
UC-11	Customer Migration from the Legacy IAM platform	**B2C/B2B**
UC-12	Relationship-Based Authorization (ReBAC) for Broker-Agency-Client Hierarchies	**B2B**
UC-13	Broker Identity Lifecycle Management via SCIM	**B2B**
UC-14	Policyholder authentication or authorization by the Contact Center Agent	**B2C**
UC-15	Consent Management	**B2C**

Classification: INTERNAL

Use Case UC-01

Self-service User Registration and Progressive Profiling

DESCRIPTION/ BUSINESS CONTEXT

Prospective and existing clients create a digital account (sign-up) during quoting, binding, or first login to the policyholder portal. IFC needs to capture only the minimum data required at signup and progressively enrich the profile as the relationship expands, without filling long forms up front.

ACTORS

Prospect Policyholder
Existing Policyholder
CIAM user registration service

TRIGGER

User selects 'Create account' or 'Signup' from the quote flow, the customer portal, or the mobile app

PRECONDITIONS

User has a valid email address or mobile number

Policy/quote number where applicable

CAPABILITIES NEEDED

Multi-Tenancy - B2C, and B2B, users partitionable across multiple tenants
Capability for IdP exposing APIs for B2C systems to trigger parts of the registration flow.
IdP orchestration parts of the registration via callouts to external IFC registration APIs
External Identity Profile (Client 360 Integration): Core user profile info (name, address, etc.) is managed by IFC's Client 360 (system of record). The IdP must be able to call external APIs on-the-fly to enrich tokens/sessions without introducing latency.

MAIN FLOW

User initiates registration and supplies a minimal identifier set (email or phone).
CIAM issues a verification challenge (email link or OTP) and confirms ownership of the identifier.
User sets authentication factors (password and/or passkey) per the insurer's policy.
System links the new identity to an existing policy/customer record, if applicable
Profile is progressively completed on later visits (address, communication preferences, dependents) rather than at initial signup.
Duplicate-account detection runs against email, phone and matched policyholder ID before the account is finalized.

DEMO

Vendor shows a demo of how a prospect or an existing customer first time signup flow
Vendor demonstrates progressive profiling: capture minimal attributes at signup, prompt for more on a later login.
Detect duplicate-account triggering on a matching email.

Classification: INTERNAL

Use Case UC-02

Passkeys/FIDO2 Passwordless Authentication with OTP and authenticator-app fallback

DESCRIPTION/ BUSINESS CONTEXT

Reduce credential-based fraud and contact center volume by moving customers toward Passkeys/FIDO2 primary authenticator while maintaining OTP/authenticator App TOTP fallback for customers with older devices

ACTORS

Policyholder
CIAM authentication service
Device authenticator provider / Platform Passkey Provider

TRIGGER

User attempts to log in to customer portal or the mobile app

PRECONDITIONS

User account exists and verified
Device supports WebAuthn/ platform authenticator, or fallback channel available.

CAPABILITIES NEEDED

UX Adoption: How does the platform nudge and guide users to enroll in passkeys?
OTP Channels & Delivery: Does the vendor provide the SMS/Email delivery network, or can we integrate our own gateways? *(Crucial for IFC short codes, cost control, and delivery SLAs).*
Governance Autonomy: Digital teams must be autonomous in configuring communications and tenant-specific settings without centralized bottleneck ticketing.

MAIN FLOW

User enters an identifier (email/username) and the authentication service determines the available authenticator methods for that user.
System detects duplicate accounts (with customizable detection logic)
System offers passkey (FIDO2/WebAuthn) as the primary method where a registered authenticator exists.
Fallback to OTP/TOTP is offered when passkey is unavailable
After successful authentication, session token issued with appropriate scopes.
User can register additional passkeys or register a new device from account settings

DEMO

Register and authenticate with a platform passkey
Show admin console configuration for required authenticator assurance level (AAL) mapped to application or transaction type
Demonstrate fallback for customers without passkey-capable devices

Classification: INTERNAL

Use Case UC-03

Account Recovery & Self-Service Credential Reset during locked-out or credential-loss scenarios

DESCRIPTION/ BUSINESS CONTEXT

Secure, self-service recovery of credentials in a credential-loss or locked-out scenario that resists account takeover techniques such as OTP interception.

ACTORS

Policyholder
CIAM recovery service
Contact center agent

TRIGGER

User selects “Forgot Password” or loses to log in to customer portal or the mobile app

PRECONDITIONS

Email, Phone or Recovery channels registered in client’s account

CAPABILITIES NEEDED

UI to support self service for user with options to configure MFA options
API’s to support integration into agents Assisted Channel User Interface (e.g. a portal) to assist with account recovery

MAIN FLOW

User initiates credential recovery.
For low-risk recovery, a time-boxed email link or OTP to a verified channel is used.
For higher-risk signals (new device, new geography, recent factor change), additional verification step or assisted recovery required
When user enters new credentials/factors; active sessions ended and a notification is sent to registered channels.
Recovery event is logged for audit and fraud analytics

DEMO

Trigger a recovery flow and show the associated risk signals
Show the agent-assisted recovery console and the audit record

Classification: INTERNAL

Use Case UC-04

Trusted Device Registration

DESCRIPTION/ BUSINESS CONTEXT

IFC existing policyholder is registering their trusted device(s) for the first time to improve security to receive OTP push notifications through the mobile application.

ACTORS

Policyholder
CIAM device registration service

TRIGGER

User selects “Register Device” after successfully signing in to the mobile app with their trusted device.

PRECONDITIONS

User account exists and verified.

CAPABILITIES NEEDED

Support for registering more than one trusted devices per user
User Self-service portal to revoking trusted devices
IdP integration with IFC mobile apps for push notifications (e.g., proprietary SDK, Firebase, Salesforce Marketing Cloud).

MAIN FLOW

User successfully signs-in to the mobile app from a trusted device
User selects ‘Register Device’ on the Application and receives a push notification on the device on successful registration.

DEMO

Vendor shows us a demo of a user, registered with 2 devices as trusted devices to support strong authentication. Vendor should be able to show additional capabilities like location if their solution supports it. If the vendors only support one device or no device registration capability, then they indicate the limitation.

Classification: INTERNAL

Use Case UC-05

Risk-based Adaptive Authentication

DESCRIPTION/ BUSINESS CONTEXT

Public facing user authentication portals are often targeted for credential stuffing, bot-driven quote scraping, and account-takeover attacks. .IFC wants authentication decisions that adapt to real-time risk signals rather than static rules alone.

ACTORS

Policyholder
Malicious actor
CIAM risk engine
Threat intel signal provider

TRIGGER

A login, registration or sensitive transaction attempt is evaluated for risk in real-time

PRECONDITIONS

Risk signal sources are integrated (e.g. IP intelligence, behavioral biometrics, bot detection)

CAPABILITIES NEEDED

Support for integrating IFC's custom proprietary fraud signals into the risk engine

MAIN FLOW

System evaluates available risk signals at the point of login/registration/transaction.
Based on a configurable risk score, the system allows, challenges (step-up), or blocks the attempt.
Risk decisions and contributing signals are logged for fraud analytics and tuning.

DEMO

Simulate a credential-stuffing pattern (e.g., rapid failed logins from varied IPs) and show the adaptive response.
Show the admin view of a specific risk decision and the source signals.

Classification: INTERNAL

Use Case UC-06

Simplified Insurance – Information Query, Document Request, Simple Transactions (Voicebot)

DESCRIPTION/ BUSINESS CONTEXT

Policyholder calls client center and performs simple information query, document request, and transactions with the Voicebot

ACTORS

Policyholder
Voicebot
CIAM Service
CCaaS (Contact Center as a Service)

TRIGGER

Policyholder calls call center and makes simple query or a transaction request (e.g. “what is my outstanding bill amount”, “email me a copy of the Proof of Insurance pink slip”, “I would like to put my on storage”)

PRECONDITIONS

Policyholder holds an active Insurance product with IFC

CAPABILITIES NEEDED

API’s to generate OTP
API’s to validate the generated OTP
API’s to send MFA authentication request to App on Registered Device and validate the response

MAIN FLOW

Policyholder calls call center and makes an information query
Voicebot greets and collects user information
CIAM service triggers step-up authentication and sends an OTP or an TOTP to user’s device
User enters the OTP via Voicebot and CIAM service validates and authenticates the user.
For sensitive requests such as “I need to change my email” one of 3 alternative options for step-up authentication is applicable - 1) approve in-app notification, 2) using code from in-app code generator, or 3) use passkeys if user has opted-in for passkey authentication.
CCaaS acknowledges authentication, invokes APIs to retrieve response and process user request (Billing API for the bill amount, Client 360 API for the Pink slip, or the Policy change API for the store transaction)

DEMO

Demonstrate information retrieval for an authenticated client via CCaaS APIs.

Classification: INTERNAL

Use Case UC-07

Simplified Insurance - Seamless App-to-Voice Transfer

DESCRIPTION/ BUSINESS CONTEXT

Customer authenticated in Mobile app wants to speak with Voicebot or an Agent

ACTORS

Policyholder
Voicebot
CIAM Service

TRIGGER

Policyholder opens mobile app, authenticates and taps 'Get an advisor' or 'Speak with a Voicebot' under the "Help" menu.

PRECONDITIONS

Policyholder holds an active Insurance product with IFC

CAPABILITIES NEEDED

API's to integrate with the CCaaS service to validate the Users Authentication Token from the mobile app

MAIN FLOW

Policyholder opens mobile app, authenticates and taps 'Get an advisor' or 'Speak with a Voicebot' under the "Help" menu.
CIAM service validates the assertion token generated by the Mobile App
A session bridge links the call with the mobile-app service
User enters the OTP received via Voicebot and CIAM service validates and authenticates the user.
For sensitive requests such as "I need to change my email" one of 3 alternative options for step-up authentication is applicable - 1) approve in-app notification, 2) using code from in-app code generator, or 3) use passkeys if user has opted-in for passkey authentication.
CCaaS acknowledges authentication, invokes APIs to retrieve response and process user request (Billing API for the bill amount, Client 360 API for the Pink slip, or the Policy change API for the store transaction)

DEMO

Demonstrate information retrieval for an authenticated client via CCaaS APIs.

Classification: INTERNAL

Use Case UC-08

Single Sign-on & Cross Application Federation

DESCRIPTION/ BUSINESS CONTEXT

Policyholders, and brokers interact with a portfolio of applications — portals, claims system, quoting engine, contact-center tools. A single authenticated session should carry across these without repeated logins, while still respecting different assurance requirements per app.

ACTORS

Policyholder
Brokerage/Broker
Relying applications (portal, apps, CRM)

TRIGGER

User navigates between two federated applications within a valid session

PRECONDITIONS

All relying applications are federated within the CIAM platform

CAPABILITIES NEEDED

Session Policies - Platform enforces distinct session lifespans and security policies for Brokers, and B2C clients from a single management plane.

MAIN FLOW

User authenticates once at the CIAM platform (identity provider).
User navigates to a second relying application, which redirects to the CIAM platform and receives a valid federated assertion/token without re-prompting the user.
Each relying application enforces its own authorization based on claims/scopes issued for that application.
Global logout from one application terminates the session across all federated applications.

DEMO

Authenticate once and navigate across two or three demo relying-party applications without re-prompting.
Trigger global logout and show session termination propagate to all connected applications.

Use Case UC-09

API Security

DESCRIPTION/ BUSINESS CONTEXT

IFC exposes internal and external APIs with third-party partners, and internal microservices. These integrations need strong client authentication, scoped tokens, and support for delegated access patterns without shared static API keys.

ACTORS

Partner system
Internal micro-service
API Gateway
CIAM authorization server

TRIGGER

A partner or internal service requests access token to consume a protected API

PRECONDITIONS

Clients are registered with the authorization server and has an agreed scope set

CAPABILITIES NEEDED

Support for JWT/Opaque Tokens , Secure Token Service (STS) token exchange patterns.
Support cryptographic keys life cycle management.

MAIN FLOW

Client authenticates using an OAuth 2.0 client-credentials or mutual-TLS/private-key-JWT flow
Authorization server issues a scoped, time-limited token reflecting only the permissions the client needs.
API gateway/resource server validates the token and enforces scope on each call.

DEMO

Register a machine client using mTLS or private-key-JWT and obtain a scoped token.
Demonstrate a token-exchange or on-behalf-of flow for a partner acting for a policyholder.

Use Case UC-10

Customizable Login Facility

DESCRIPTION/ BUSINESS CONTEXT

Each IFC brand needs its own login, registration, and recovery experience. The IDP platform and operations are centralized. The brand experience shall be configurable without a new release of the platform.

ACTORS

Policyholder
Brand Marketing
IAM Operations personnel
CIAM service

TRIGGER

User connects to a login or registration page from a brand-specific domain

PRECONDITIONS

None

CAPABILITIES NEEDED

Delegated Administration (RBAC): Restrict access to digital teams to manage only their respective tenant configs
Platform to support multiple custom IdP URL's (e.g. idp.brand1.com, idp.brand2.com, idp.brandX.com)
Login UI Customization per brand URL

MAIN FLOW

User connects to the customer portal of the brand specific domain
Platform renders a brand-specific theme, language set, legal text, consent wording and customer support links
Brand specific policies are applied (e,g, MFA, registration, etc.)
One account across brands or one account per customer as per IFC policies for policyholders across multiple IFC brands.

DEMO

Show two brands on custom domains with unique themes, languages (French and English), and policies applied.

Classification: INTERNAL

Use Case UC-11

Legacy IAM Migration

DESCRIPTION/ BUSINESS CONTEXT

IFC's existing policyholder and broker credential stores must migrate to the new CIAM platform without forcing a mass password reset or a service outage, and without losing linkage to existing policy records.

ACTORS

Policyholder
Broker
Legacy ISM/Credential Store
CIAM migration tooling

TRIGGER

A user with a legacy credential authenticates for the first time after cutover, or a bulk migration batch runs.

PRECONDITIONS

Legacy credential store data is available for migration (hashes, profile attributes, entitlements)

CAPABILITIES NEEDED

Just in Time Migration workflow when user logs in to new IdP for the first time
Bulk migration capabilities with ability to reset password for bulk migrated users

MAIN FLOW

Credential secrets are migrated using a supported just-in-time or secure hash-import mechanism.
On first login post-cutover, if a just-in-time pattern is used, the platform verifies against the legacy store transparently and re-hashes into the new platform without prompting the user for a reset.
Existing account-to-policy and account-to-brokerage linkages are preserved or explicitly re-validated.
A rollback path exists in case cutover issues are discovered post-migration.

DEMO

Walk through of the vendor's reference migration architecture and a prior financial-services migration of comparable scale.
Demonstrate, if feasible, a just-in-time migration login for a sample legacy hash format.

Classification: INTERNAL

Use Case UC-12

Relationship-based Authorization for Broker Access to Policyholder data

DESCRIPTION/ BUSINESS CONTEXT

Access to a policyholder's data should follow the actual business relationship: a brokerage can see clients placed through their brokers; a broker who leaves a brokerage loses access immediately. Static role-based access control does not model this well at scale.

ACTORS

Brokerage
Brokers
Policyholder records
Fine-grain authorization service

TRIGGER

Any read/write request against a policyholder or account must be authorized against the requester’s relationship to that account

PRECONDITIONS

Relationship graph (brokerage-broker-client-policy) populated and kept in sync with source system

CAPABILITIES NEEDED

Confirm the IdP can call an external IFC rules engine during the token minting pipeline to write specific claims into the token.

MAIN FLOW

Application makes an authorization check call (e.g., "can producer X view policy Y") to the fine-grained authorization service.
Service evaluates the relationship graph, and returns allow/deny with the reasoning path.
Relationship changes propagate to the graph and take effect for subsequent checks.

DEMO

Model a brokerage-broker-client hierarchy and demonstrate an access check that correctly reflects an inherited relationship.
Reassign a broker to a different brokerage and show access change.
Run a listing query "all resources this user can access"

Use Case UC-13

Broker Automated Lifecycle Management via SCIM

DESCRIPTION/ BUSINESS CONTEXT

Broker identities manual account creation/deprovisioning is a slow process and a security risk when offboarding is delayed. A standards-based, automated broker identity lifecycle sync is a preferred and secure approach.

ACTORS

HR System (Broker identities source of truth)
SCIM provisioning connector
CIAM directory

TRIGGER

Broker new hire, role change, transfer, or termination event occurring in the Broker source system

PRECONDITIONS

Source system supports SCIM 2.0

CAPABILITIES NEEDED

User Management API's
SCIM support for user synchronization to Intact Internal User store

MAIN FLOW

Source system event (create/update/deactivate) is sent to the CIAM platform via SCIM 2.0.
CIAM platform provisions, updates, or deactivates the identity and its entitlements accordingly.
Deactivation immediately revokes active sessions and downstream application access, not just the directory entry.
Provisioning errors are logged to an operations queue

DEMO

Send a SCIM deactivation event and demonstrate session revocation and access loss within an agreed time window.
Show the log for both successful and failed identity deprovisioning event

Use Case UC-14

Policyholder Authorizing Call Center Agent via CIBA

DESCRIPTION/ BUSINESS CONTEXT

The call center agent handling user call would like to access the caller's personal information on their computer. The user can consent to this by, for example, approving a push notification on their phone.

ACTORS

Policyholder
Contact Center Agent
Consumption Device (Agent's desktop)
CIAM admin console

TRIGGER

The call center agent retrieves user's information from their device.

PRECONDITIONS

Agent has a role in the CIAM admin console

CAPABILITIES NEEDED

User Management API's
Support Authentication of user initiated by an Agent in lieu of the user through back channel authentication

MAIN FLOW

The client application or consumption device (Agent's device) requests user authentication or authorization request
CIAM service receives the authorize request and sends a notification to the authentication device (User's device)
The user reviews the request and provides their response to the CIAM service
Client application receives the appropriate tokens and presents user's personal information on the Agent's device

DEMO

Show the support agent console triggering channel-based caller verification
Show an example agent action e.g. unlock caller account post successful authentication
Show the audit log entries

Classification: INTERNAL

Use Case UC-15

Consent Management

DESCRIPTION/ BUSINESS CONTEXT

IFC captures and honors granular user consent under PIPEDA and applicable provincial privacy statutes. User would like to provide consent to organization to share its personal and financial information with a 3rd party. This consent will be active for a time-period, and applicable to the accounts selected by users. The consent would contain information of granular data clusters (set of data) that user agreed to share. There might be an organizational requirement of renewing the consent before it expires. Organization to manage E2E consent lifecycle while providing data access as per consent scope.

ACTORS

Policyholder
CIAM consent service

TRIGGER

User updates communication or data-sharing preferences, or submits a data access/deletion request

PRECONDITIONS

None

CAPABILITIES NEEDED

Granular Data Scopes; Time-bound Consent;
Fetch and enforce consent status during login to dynamically restrict token scopes/claims

MAIN FLOW

User views and updates consent preferences from a self-service center.
Consent changes propagate to downstream systems with a timestamped record of what was consented to and when.
User submits an access or deletion request; request is logged, routed for fulfillment, and tracked to a committed SLA.
Organization can produce an audit-ready export of an individual's consent history on demand.

DEMO

Vendor shows us a demo of how organization can dynamically register clients with their authorization scopes captured.
How user can provide consent and how consent lifecycle would be managed.
Produce a sample audit export of one identity's consent history